

Configuration & Vulnerability Management Policy

1. Purpose and Scope

This policy establishes Hewlett Packard Enterprise's (HPE) requirements for securely configuring, maintaining, and continuously assessing all information systems, endpoints, network devices, container images, and cloud workloads across the enterprise. It applies to every asset owned, operated, or managed by HPE, including on-premises data centers, hybrid environments, and third-party cloud platforms. The objective is to ensure that systems are provisioned from a known-secure state, kept current against emerging threats, and continuously validated against recognized industry standards.

2. Secure Baseline and Hardening Configurations

Every system class deployed at HPE must be built from an approved standard build derived from a documented golden image. These baseline configurations define the authoritative hardened state for operating systems, middleware, databases, and container base images. Hardening requirements are aligned to CIS Benchmarks as the primary reference. Where systems support regulated or government workloads, the applicable DISA STIG guidance is layered on top of the CIS baseline to satisfy stricter federal requirements. Additional industry standards, including NIST SP 800-53 and vendor security guides, are incorporated where they address gaps not covered by CIS or STIG.

Golden images are version-controlled, cryptographically signed, and stored in a centrally governed artifact repository. Baselines are reviewed at least annually and whenever a benchmark revision, major OS release, or significant threat change occurs. Manual, one-off system builds outside the approved baseline are prohibited.

3. Infrastructure-as-Code and Automation

HPE provisions and configures infrastructure primarily through infrastructure-as-code (IaC). All hardening controls, package versions, and security settings are codified in declarative templates (Terraform, Ansible, and Kubernetes manifests) and delivered through automated CI/CD pipelines. This orchestration-driven approach guarantees that the hardened baseline is applied consistently and repeatably at every deployment, eliminating human error inherent in manual configuration.

Security controls are embedded directly into the pipeline: IaC templates are statically scanned for misconfigurations before merge, and no build may promote to production without passing automated policy gates. Automation enforces that the running state of an asset always matches its codified definition, and pipelines re-apply the golden configuration on every release to prevent silent divergence.

4. Patch and Vulnerability Management

HPE maintains a continuous patch management program covering operating systems, applications, firmware, and container images. Security updates, hotfixes, and vendor patches are evaluated against risk and deployed according to defined service levels based on severity:

- Critical vulnerabilities: remediated within 7 days
- High: remediated within 30 days
- Medium: remediated within 90 days
- Low: remediated during the next scheduled maintenance cycle

Newly identified vulnerabilities are triaged using CVSS scores enriched with threat intelligence and exploitability data. Wherever feasible, remediation is delivered by rebuilding from an updated golden image and redeploying through the pipeline rather than patching live systems in place, ensuring the fix is durable and reflected in the baseline.

5. Compliance Scanning and Assessment

Automated compliance scanning runs continuously across the estate. Authenticated configuration checks measure each asset against its assigned CIS Benchmark and STIG baseline, while vulnerability scanners perform recurring assessment of exposed weaknesses. Scan results feed a centralized dashboard that reports posture by business unit and asset class. Internal and independent audits are conducted periodically to validate that scanning coverage, controls, and remediation timelines meet policy and regulatory obligations.

6. Configuration Drift and Deviation Handling

Any deviation from the approved baseline is treated as a security event. Continuous monitoring detects configuration drift by comparing the live state of assets to their codified IaC definitions and hardened baselines. When unauthorized variance is identified, automated remediation restores the system to its known-good state, or the drift is escalated to the system owner for investigation.

Legitimate business needs that require departing from a baseline must be documented through the formal exceptions and waivers process. Each requested exception must include a business justification, risk assessment, compensating controls, and an approved expiration date. Waivers are reviewed and reauthorized at defined intervals by the Security Governance team; expired exceptions are automatically flagged as non-compliant.

7. Roles and Enforcement

The Information Security organization owns this policy, maintains the baseline library, and operates scanning and reporting tooling. System and application owners are accountable for remediating findings and keeping their assets compliant. Violations of this policy may result in system isolation, revocation of deployment privileges, and disciplinary action.

8. Review

This policy is reviewed at least annually and updated in response to changes in CIS Benchmarks, STIG releases, regulatory requirements, or the HPE threat landscape.